# Thinking Chains (Proof of AI): Adversarial Soundness Review

Red-team audit of the Tier-0 governance contracts, the visibility surface, the issuance coin, and the economic-security claims

Zoo Labs Foundation
research@zoo.ngo

Review date: 2026-06-22

**Abstract**

We record an adversarial review of the *Thinking Chains* (Proof of AI) stack: the on-chain Tier-0 governance contracts (`ThinkingGovernor`, `ProofOfThoughtRegistry`, `ThinkingChainObservatory`, `GovernancePoTBridge`, `ThinkingReputation`, `L3Registry`, `AICoin`), the off-chain operator (Go) that signs verdicts in parity with the Solidity contracts, the DAO visibility dashboard, the local two-chain proof harness, and the formal/economic claims of the two companion papers. Five independent adversarial reviewers attacked five disjoint surfaces. No theft, consensus-compromise, or cap-violation was found; the conceptual core (deterministic replay over authenticated artifacts; the $10^9$ capped, halving, provably-bounded issuance) held under analysis and fuzzing. The review did find, and we fixed, real integrity bugs on the *visibility* layer (an unauthenticated receipt ledger, a deterministic-id front-run, a dashboard arithmetic DoS, a stored XSS, a proof harness that displayed rather than asserted), a cross-instance/cross-chain signature-replay gap (missing EIP-712 domain separation), and several *overstated economic-security claims* in the papers (a Sybil-inviting routing exponent, a quorum bound valid only for equal-vote committees, a reputation rule mis-described as a proper scoring rule, and a subsidy that did not require provable work). All contract fixes are covered by tests (135/135) and a live end-to-end proof (9/9 on-chain assertions); all paper claims are tightened or downgraded to defensible statements. This document is the durable record of what was attacked, what held, what changed, and the residual trust assumptions.

## 1 Scope and method

**System under review.** A Thinking Chain settles cognition and mints a coin for it. Two layers are in scope here. **Tier-0** is a set of EVM-agnostic Solidity contracts (the DAO governance: operator-LLM quorum decides on-chain knobs; a deterministic receipt ledger; a reputation EMA; the native coin's issuance) deployed to any EVM. **Tier-1** is the in-protocol AI precompile (a deterministic int8 inference path) implemented in the Rust revm/reth execution client; the precompile's inference correctness is out of scope for this review, but its determinism is the premise that makes "deterministic recomputation" a valid evidence type (Section 4). The off-chain operator that reads the chain and signs verdicts is Go (the Zoo-L3 node path), and is held in byte-parity with the Solidity digest by golden vectors.

**Threat model.** Adversaries may: open governance thoughts with arbitrary parameters; bond and submit signed verdicts; call any public method from any address; deploy duplicate or malicious contracts; front-run; and supply malicious on-chain strings consumed by off-chain readers. They

may not break secp256k1, keccak256, or the BFT consensus the chain runs under. The inference precompile and the engine are trusted to be deterministic where claimed.

**Method.** Five independent reviewers attacked disjoint surfaces: (R1) `AICoin` issuance; (R2) `ThinkingGovernor`; (R3) the observatory and auxiliary contracts; (R4) the papers' theorems and economic mechanism; (R5) the proof harness, deploy scripts, and dashboard. Each was required to produce concrete proof-of-concept (a failing test or explicit call sequence), to default to skepticism, and to state plainly what it could *not* break. Findings below are de-duplicated and dispositioned.

## 2 On-chain invariants (held; now test-pinned)

The following are the load-bearing safety properties. Each was attacked and held; each is now pinned by a named test in the `luxdao/contracts` suite (135 tests green) and, where end-to-end, by the local two-chain proof (`beluga-l3-live.sh`, 9/9 assertions).

**Proposition 1** (Issuance cap)**.** *For all timestamps and all sequences of `mintSubsidy` calls, cumulative minted subsidy never exceeds $S_{\max} = 10^9$ AI.*

*Argument.* Minting is bounded by `emissionAllowance()` = `cumulativeAllowance()` − `mintedSubsidy`. The schedule $\text{allowed}(t) = S_{\max}\big(1 - 2^{-k}\big) + f\, S_{\max} 2^{-(k+1)}$, $k = \lfloor t/T_h \rfloor$, $f \in [0,1)$, is continuous, strictly increasing, and bounded above by $S_{\max}$ (the per-epoch emissions $S_{\max}2^{-(k+1)}$ sum to $S_{\max}$); the floor rounding of the intra-epoch term is conservative (undershoots). Hence `mintedSubsidy` $\le$ allowed$(t) \le S_{\max}$. Verified by exact-integer modelling over $k \in [0, 128]$ at one-second resolution and by a 2000-run sequential fuzz (`testFuzz_SequentialCapWalk`); over-minting by one wei reverts at every sampled timestamp. □

**Proposition 2** (Supply ≤ minted; dashboard cannot underflow)**.** *`totalSupply` ≤ `mintedSubsidy` always, so the observatory's `burned` = `minted` − `circulating` is non-negative.*

*Argument.* `mintedSubsidy` increases only inside `mintSubsidy`, by the same amount passed to `_mint`; the only supply-reducer is `burn`; there is no other mint path (OpenZeppelin `_mint` is internal and not otherwise exposed). As defence in depth against a *non-canonical* `IAICoin` wired into the observatory, `economics()` now clamps `burned` = max(0, `minted` − `circulating`) rather than risk an underflow revert that would DoS the entire dashboard. □

**Proposition 3** (Receipt authenticity)**.** *Only authorized recorders may write a Proof-of-Thought receipt; a receipt cannot be forged by an arbitrary caller, nor can its deterministic id be front-run to block or poison a legitimate governance receipt.*

*Argument.* `register` is gated by an `isRecorder` allow-list under a DAO `admin`; the `GovernancePoTBridge` is the authorized recorder for governance receipts. Before this fix `register` was permissionless, which allowed (i) receipts attributing paid cognition to arbitrary payer/operator and inflating the dashboard's volume metric, and (ii) a front-run of the deterministic `receiptId` (all inputs public) that permanently blocked the bridge's write and injected a forged `quorumProof`. Gating writers closes both. Pinned by `test_Register_OnlyRecorder`. □

**Proposition 4** (Verdict signature domain separation)**.** *A verdict signature is valid only for the governor instance and chain it was produced for.*

*Argument.* The signed digest now binds `block.chainid` and `address(this)` in addition to the purpose domain, task, model spec, vote, bucket, evidence, and operator. Without this, an operator's own re-submission of a byte-identical signature could manufacture a quorum on a fork, an L2, or a same-address twin (the prior `signer==msg.sender` check blocked third-party relay but not self-replay across instances). Go operator mirror and the cross-language golden vector were updated in lockstep (chainId 808080, verifying contract `0x..beEF`); the contract layout is pinned by `test_GoldenVerdictDigestParity`. □

**Remark 1** (Settlement robustness)**.** *The knob mirror to the DAO key/value singleton is now gas-capped (`{gas:200,000}`) so a gas-burning (vs reverting) singleton cannot brick or tax `settle` via the 63/64 rule. The `L3Registry` gained a DAO-gated `reassign` to recover a squatted chainId and a zero-address guard on the authority transfer.*

## 3 Findings and dispositions

| Sev | Finding | Disposition |
|---|---|---|
| HIGH | Permissionless `register` ⇒ forged receipts + metric poisoning (R3 F2) | Fixed: recorder allowlist |
| HIGH | Deterministic-`receiptId` front-run DoS + forged proof (R3 F3) | Fixed (same gate) |
| HIGH | `L3Registry` chainId squatting bricks a real L3 (R3 F4) | Fixed: DAO `reassign` |
| HIGH | Verdict signature replay across instances/chains (R2) | Fixed: chainId+verifyingContract |
| HIGH | Stored XSS via on-chain `knobKey` → `innerHTML` (R5) | Fixed: HTML-escape |
| HIGH | Proof harness displayed state but never asserted it (R5) | Fixed: 9 hard assertions, fail-closed |
| CRIT† | Routing exponent $\alpha < 1$ *invites* Sybil-splitting ($m^{1-\alpha}$ gain), claimed to "blunt oligarchy" (R4) | Fixed in paper + DAO params |
| HIGH† | `thm:quorum` Hoeffding bound false for weight-proportional committees (R4) | Restated: equal-vote regime |
| HIGH† | Subsidy mintable by a free signed artifact (no real work) (R4) | Paper: subsidy requires provable-work evidence |
| HIGH† | `lem:dissent` mis-states EMA as a proper scoring rule (R4) | Paper: slash-only claim; proper-scoring/dispute game deferred to Zoo DAO |
| MED | `economics()` underflow DoS for a non-canonical coin (R3 F1) | Fixed: clamp |
| MED | KVP mirror gas-grief can brick `settle` (R2) | Fixed: gas cap |
| MED | `transferZooDAO(0)` bricks endorsement authority (R3 F5) | Fixed: zero guard |
| MED | Cognition provenance hidden by `2>/dev/null` in the harness (R5) | Fixed: `COGNITION SOURCE` banner |

| Sev | Finding | Disposition |
|---|---|---|
| MED† | `thm:issue` "entire 1B minted" overstated (supremum; integer dust) (R4) | Paper: supremum + integer note |
| MED† | `thm:pot` independence of evidence types assumed (R4) | Paper: independence hypothesis; correlated → max |
| LOW | `overview()` unbounded loop; gas cliff ∼10k tasks (R3) | Accepted; `recentThoughts` paginated; O(1) counters tracked |
| LOW | Non-YES quorum pays committee, no opener refund (R2) | Accepted (paid for judgment, not outcome); documented |
| LOW | {vote,bucket} grouping: unanimous-YES at split buckets fails to settle (R2) | Accepted; off-chain bucket coordination |
| LOW | `ThinkingGate` binds only `taskId`, not intent (R3 F6) | Documented: consumers fix/validate `taskId` |
| LOW | `ThinkingReputation` double-counts under a non-canonical governor (R3 F7) | Not exploitable on canonical governor; documented |
| LOW | `esm.sh` import without SRI (R5) | Accepted; vendor/pin tracked |
| INFO | Minter centralization bounds fair-launch to settlement+admin trust (R1) | Documented trust assumption |
| INFO | `HALVING_PERIOD` leap drift (1 day / 4 yr) (R1) | Cosmetic; cap unaffected |

Table 1: Red-team findings. † = paper/mechanism claim (corrected in the LaTeX), not an exploitable contract bug. No Critical/High contract-exploit (theft, consensus-break, cap-violation) was found.

## 4 Economic-security caveats (now corrected in the papers)

The review's sharpest contribution was on the *economic* claims, which were stated too strongly. The corrected, defensible positions:

- **Sybil-resistance is a cost, not an exponent.** A concave bond weight $B^\alpha$ ($\alpha < 1$) is subadditive, so splitting one bond across $m$ identities yields $m^{1-\alpha}B^\alpha > B^\alpha$: concavity *rewards* fragmentation. Resistance must come from a per-identity registration cost and stake floor (splitting net-negative) and a per-identity committee-weight cap, specified in the Zoo DAO paper—not from the exponent.
- **Quorum capture is exponentially rare only for equal-vote committees.** The bound $\exp(-2n(\theta - p)^2)$ holds when each seat is one equal vote sampled independently of weight. Under weight-proportional sampling and weighted certification, a sub-threshold heavy node

can capture with probability near 1. Safety-critical quorums therefore certify by equal seats; weighted committees require a per-seat weight cap and yield a strictly weaker, cap-dependent guarantee.

- **Subsidy requires provable work.** A signed finite judgment is free to produce, so minting cannot be gated on a bare quorum signature without inviting work-free coinage. Subsidy minting is gated on provable-work evidence (deterministic recomputation of the int8 model, attestation, or zkML); quorum-only judgments earn demand fees but do not mint. This restores the Bitcoin-style cost-asymmetry ("no coin without a thought") for cognition.
- **Reputation is coordination, not truth.** The EMA rewards agreement with the canonical (quorum) outcome, which is not ground truth; for subjective tasks it is not by itself incentive-compatible for honest minority reports. The "slash liars, not dissenters" principle is sound as a *confiscation* policy (dissent is never slashed); truth-elicitation for subjective, money-moving decisions uses a proper scoring rule against later-revealed outcomes or a bonded dispute game.
- **Issuance cap is a supremum.** $M(t) \uparrow S_{\max}$ strictly and never reaches $10^9$ over any finite horizon; in integer base units the schedule floors to zero in finite time leaving a negligible dust remainder below the cap.

What *held* on the conceptual side: the determinism result (deterministic replay over authenticated artifacts) is sound and resolves the "LLMs are nondeterministic, so you cannot replay" objection—consensus consumes committed artifact bytes via deterministic predicates, never a live generation; the recursive-upgrade-termination and training-provenance-audit results are correctly proven; and the single-evidence receipt-soundness bound is a valid restatement of the verifier's trust assumption.

## 5 Permissionless-network readiness (second red round)

A second adversarial round asked the deployment question directly: is this safe on a *public permissionless* network where anyone may register (pay `minBond`), open rounds, submit, and settle, and where an attacker can cheaply spin up many bonded identities and front-run? Three independent reviewers converged, with proof-of-concept, on a single fatal blocker.

**Theorem 5** (Permissionless committee-capture blocker, pre-fix)**.** *With recoverable bonds and first-come committees (no sampling), an adversary captures any committee—and thus any governed knob or median—for a sunk cost of at most one open fee, independent of committee size: register $n$ Sybil identities (cost $n \cdot$ `minBond`, fully refundable), fill the committee, sign the desired outcome, settle, then reclaim every bond and (being the agreeing group) the reward escrow.*

The PoCs demonstrated arbitrary knob capture on `ThinkingGovernor` (net sunk cost = open fee, bonds + reward recovered) and *free* median capture on `ThinkingParameters` (no fee, no cap, no sampling). Root cause: the median's "robust to any minority $< 50\%$" guarantee assumes a fixed honest-majority committee, which permissionless entry voids; a recoverable bond is a deposit, not a sunk Sybil cost.

**Fix (no-slashing-of-dissent honored).** Two changes, structural and economic, neither of which slashes a dissenter:

1. **Cryptographic sortition** (`Sortition.sol`): each round's committee is sampled by $H(\text{seed} \,\|\, i) < 2^{256} n/N$ with a seed fixed *after* registration and round-open (a future block hash), so committee share tracks population share and capturing a committee needs a *population majority* (core paper, Thm. "Sortition capture requires a population majority"; verified in `Sortition.t.sol`: a 40% adversary stays a committee minority, 70% gains it).

2. **A non-refundable registration / participation fee** (a *sunk* per-identity cost—never a slash): acquiring a population majority then costs $\Omega(N)$ in sunk capital.

**Status by contract.** `ThinkingParameters` (the most exposed surface—free median capture) is *fixed and proven*: `submitProposal` now requires the proposer be registered before the round opened *and* sortition-sampled; the committee is bounded to $n$; a non-refundable `proposalFee`/`openFee` (sunk to treasury) prices each seat and deters spam; a minimum window blocks flash open-and-settle lockout. `ThinkingGovernor` received the additive sortition *foundations* (`operatorCount`, `operatorSince`, registration block) with zero behavior change (84 tests stay green); its vote-committee receives the identical sortition + non-refundable registration fee as the immediate next step (the pattern is validated on `ThinkingParameters`). Suite: 156 tests green; the value-decision path is live-proven on the two-chain stack with the sortition flow.

**Honest readiness statement.** The value-deciding path is permissionless-safe. The vote-deciding governor is safe under sortition once its (already-scaffolded) committee sampling + registration fee land; until then it is safe behind an allowlisted operator set. No theft, consensus break, or cap violation exists in either; the gap was committee *capture*, now closed structurally for values and scaffolded for votes.

## 6 Residual trust assumptions

1. **Minter custody.** `AICoin` enforces the issuance envelope (cap + halving) on-chain; *fairness* of distribution is delegated to the settlement contract authorized as minter and to the `admin` key. The cap bounds the blast radius of a compromised minter to no more than the honest schedule would have emitted.

2. **Deterministic precompile.** "Deterministic recomputation" evidence ($\eta_e = 0$) is valid only for the fixed-point/int8 inference path with a canonical execution spec; floating-point inference on heterogeneous hardware must use signed-judgment or attestation evidence.

3. **Composition.** `ThinkingChainObservatory`, `ThinkingGate`, and `ThinkingReputation` accept arbitrary governor/coin implementations; their guarantees are stated against the canonical contracts. L3s wiring their own implementations inherit the obligation to meet the same invariants.

4. **BFT and cryptography.** secp256k1, keccak256, and the underlying post-quantum BFT consensus are assumed unbroken.

## 7 Conclusion

The Thinking Chains spine is sound: issuance cannot exceed its cap, the receipt ledger is now authenticated, verdict signatures are domain-separated, and the deterministic-replay guarantee holds. The defects the review surfaced were concentrated where new surface was added—the

visibility layer and the economic claims—and have been fixed (contracts, with tests) or tightened (papers, to defensible statements). The honest headline: the cryptographic and state-machine core is publishable as-is; the economic-security mechanism is sound only with the Sybil-cost, equal-vote-quorum, provable-work, and dispute-game provisions now made explicit. The bound that matters most—a coin is minted only by verifiably-performed, capped, halving cognition—survives.